

Motio User System Specification

Context

This document defines the complete user system for the Motio internal dealership application. The system is designed for employees only. There are no guest users, no public access, and no self-registration. All accounts are created and managed by Admin users, and all access is enforced via role-based authorization.

Core Principles

All access requires authentication. Users cannot self-register. Accounts are created by Admins with a temporary password. First login requires a forced password change. Role-based access must be enforced at both API and UI level.

Roles

Admin has full control of the system including user management and critical operations. Hybrid users have operational control but no user management access. Innkjøper users handle car intake and manage assigned vehicles. Selger users handle sales and pricing. Klargjører users handle preparation workflows only.

Permission Enforcement

Permissions must be enforced in backend middleware. UI-only restrictions are insufficient. Each endpoint must validate the authenticated user's role and ownership where applicable.

Account Lifecycle

Admin creates user accounts with a temporary password. Users are forced to change password on first login. Admins can reset passwords at any time, triggering a new forced password change.

Security and Auditing

Sensitive actions must be logged in an audit table. This includes role changes, pricing changes, sales actions, and compliance status updates. All sensitive state transitions must be traceable.

Final Rule

Any action affecting money, compliance, customer data, or accountability must be role-restricted, validated, and logged.